Entity-conditioned nulls for anomaly detection in authentication logs

Abstract

Anomaly detection on security telemetry is usually posed as outlier detection against a pooled population. We argue and then measure that this asks the wrong question: an account that is permanently unusual is not thereby suspicious, and an account that has changed is suspicious whether or not it is unusual for the organisation. We therefore condition each null on the entity that produced the event, so that the reference set for an authentication is that account's own history.

On the Los Alamos authentication corpus, where 549 labelled red-team events occur among 4.19 million scored events, a per-entity novelty test attains 15.7% precision (95% CI 9.0–26.0) at 10 alerts per analyst-day against a base rate of 1.31×10^{-4}, a lift of about 1,200. A structural census locates the mechanism: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, while the property a population-rarity test expresses contains none of them.

Five negative results are of independent interest. Combining the detectors' p-values, by Fisher's method with Brown's correction or by the Šidák-corrected minimum, never exceeds the best single component. Alerting whenever any detector ranks an event highly is strictly dominated at equal cost and superior at equal depth, at 3.7 times the alert volume. Dividing the budget by demonstrated quality does not help either, and the failure is bounded rather than observed: an exhaustive search over splits, chosen with the labels in hand, finds the optimum at the corner. What decides whether a division pays is the overlap between two detectors' detections — 74.6% between the two strongest, and 0% in the one configuration where a split wins. Read as a zero-sum game against an adversary choosing the mechanism, the corner result is a theorem rather than a measurement, and the portfolio's game value is exactly zero: every detector is blind to one planted mechanism, so no reweighting helps and the defect is coverage, not allocation.

Keywords: anomaly detection; multiple testing; conditional inference; game theory; intrusion detection; decision theory.

---

1. Introduction

1.1 The operational problem

An enterprise authentication log records who authenticated to what, from where, and how. A record from the corpus studied here carries nine fields: a timestamp, source and destination account, source and destination computer, an authentication type, a logon type, an orientation, and success. An uninterpretable value is written `?`, a distinct state from absence and treated as one throughout.

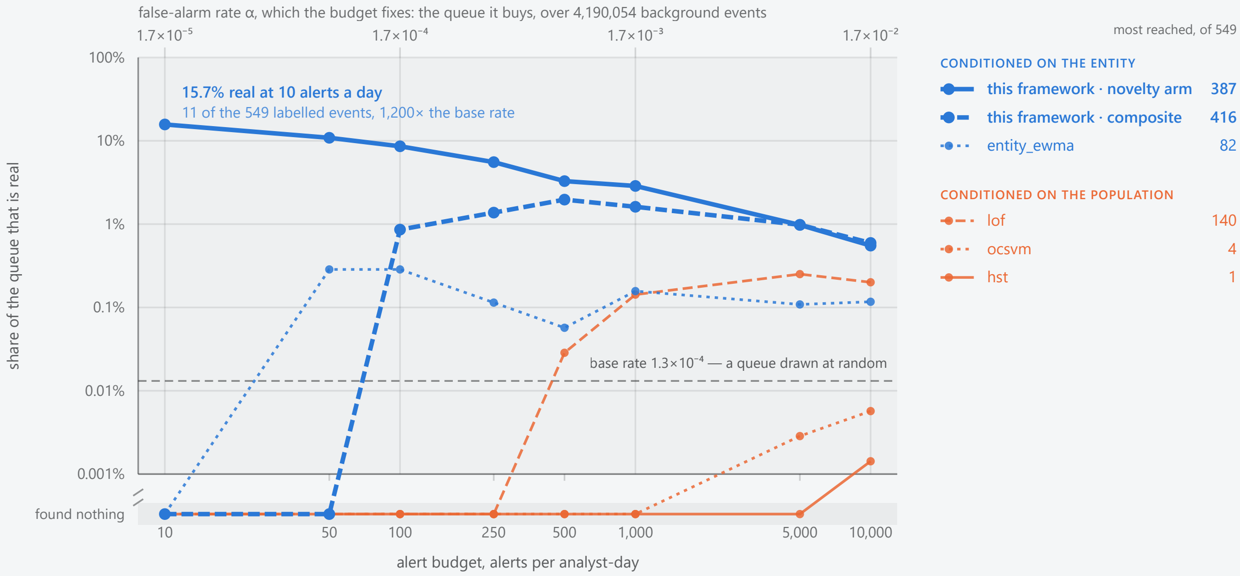
Two features of the setting bound what any method can achieve. The first is volume against rarity: 42.2 million events were scored over seven days and 549 are labelled, a base rate π of 1.30×10^{-5}. With α the per-event false-alarm rate,

```
P(intrusion | alarm) = π / (π + (1 − π)·α),
```

so half a queue is real only at $\alpha \approx 1.3 \times 10^{-5}$, about 78 false alerts a day; at $\alpha = 10^{-3}$, an operating point typical of published detectors, the same corpus yields some 6,000 false alerts against 78 real ones. This is Axelsson's base-rate argument [1] on our own data.

Share of the alert queue that is real, at each alert budget

4,190,603 events scored over 7 days · 549 labelled · a base rate of one in 7,633. Grouped by the scope of the null each method tests.



The comparison is a function of the budget, not a point. Every line is measured on the same slice: 4,190,603 scored events over 7 days, of which 549 are labelled, a base rate of one in 7,633. Each point is one method at one measured budget. A method that found nothing at a budget is drawn on the *found nothing* row below the axis break rather than omitted, so a flat line there reads as measured rather than as missing; the methods leave that row at six different budgets, which is the comparison this figure exists to make.

Colour is the scope of the null, not who wrote the method. Blue judges an event against the history of the account that produced it, orange against the pooled population (§1.2). `entity_ewma` is a comparator drawn in blue because it keeps a per-entity mean; this framework's arms are the heavier strokes in that family, and every method's scope is recorded in the curve file. A method's own α is lower than the budget's by the detections it found, at most 16% at 10 alerts a day and 0.6% at 10,000.

The figure draws the four comparators with the most detections over the budget range, so the choice does not flatter this framework; the other four reached too little to plot, and the table below lists all eight that were run. *Every reading here is an upper bound on this framework's disadvantage and a lower bound on its precision.* The corpus has no true negative class, so an unlabelled alert on genuine but unrecorded malicious activity counts as a false alarm (§12.5). The baselines read a fixed-length numeric vector per event and only `entity_ewma` holds per-entity state; they are not held to R2 or R4 (§12.4).

METHOD	JUDGED AGAINST	100 ALERTS / ANALYST-DAY			1,000 ALERTS / ANALYST-DAY		
		FOUND	PRECISION	RECALL	FOUND	PRECISION	RECALL
this framework, novelty arm	its own history	60	8.6%	11%	201	2.9%	37%
this framework, composite	its own history	6	0.86%	1.1%	113	1.6%	21%
entity_ewma	its own history	2	0.29%	0.36%	11	0.16%	2.0%
lof	the population	0	0	0	10	0.14%	1.8%
ocsvm	the population	0	0	0	0	0	0
hst	the population	0	0	0	0	0	0
rrcf	the population	0	0	0	0	0	0
eif	the population	0	0	0	0	0	0
iforest	the population	0	0	0	0	0	0
pca	the population	0	0	0	0	0	0

Every method that was run, at two budgets. A budget of *b* alerts per analyst-day buys a queue of $b \times 7$ alerts over the 7 days scored, whichever method spends it. *Found* is labelled events reached, *precision* the share of the queue that is real, and *recall* the share of the 549 labelled events reached.

Most of the comparators reach nothing at all: seven of the eight at 100 a day and six of the eight at 1,000 a day. A zero is measured, not missing — every method read the same events, which is why the figure above needs a row below its axis.

This framework's novelty arm reaches 11% of the campaign at 100 alerts a day and 37% at 1,000, against a base rate of 1.3×10^{-4} — a lift of 650× and 220×.

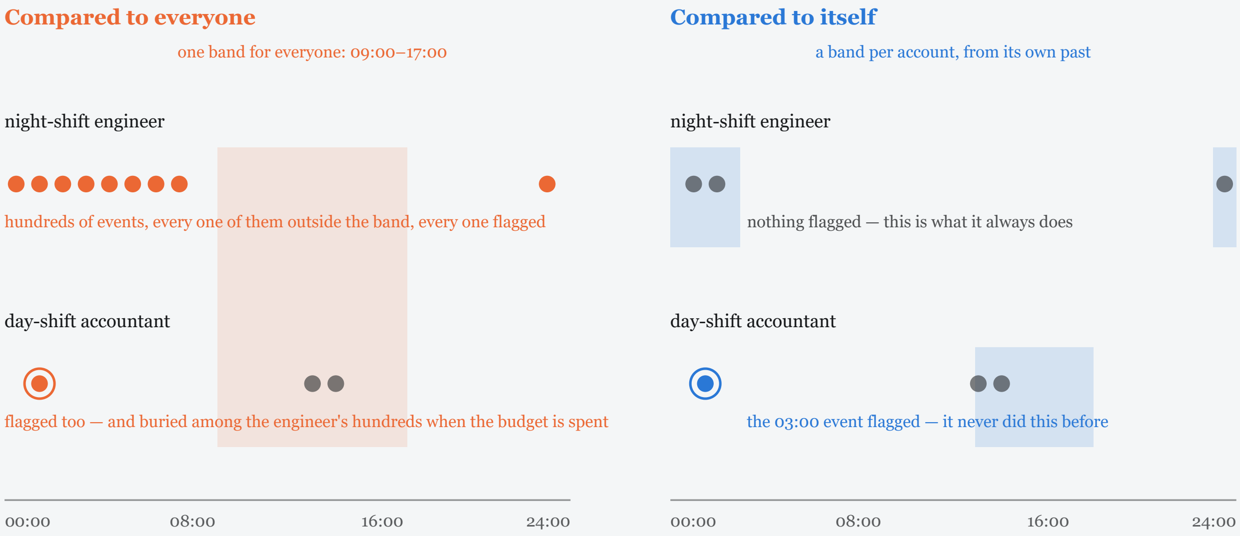
Recall counts what the red team wrote down, not what happened. The label file records an authorised exercise rather than annotating the log exhaustively, so unrecorded malicious activity counts against precision and is absent from the recall denominator (§12.5): both columns are lower bounds. Only `entity_ewma` holds per-entity state, and no comparator is held to R2 or R4 (§12.4).

The second is that the consumer is a person with a fixed working day. Triage capacity is a staffing constant, not a tuning parameter, which is why every comparison here is made at a matched number of alerts per analyst-day and never at a matched threshold: two methods thresholded alike may emit volumes differing by three orders of magnitude, and the comparison would then be between their volumes.

Suppressing false alarms is therefore not this framework's binding constraint — it already reaches labelled events at every budget where the comparators reach none. Recall is.

The labels shape every figure. A red team's label file records what its members did; it is not an exhaustive annotation of the log. Malicious activity the red team did not record counts as a false positive, so every precision figure here is a **lower bound**, and the recall denominator is what was written down.

1.2 Why a population-scope null asks the wrong question



The reference moves with the account. Both panels hold the same two accounts and the same events. On the left one band serves everyone, and the failure is not that the accountant's 03:00 event goes unflagged — it is flagged. It is that the night-shift engineer is flagged on *every event it ever produces*, so the day's alert budget is spent on accounts that are behaving exactly as they always have, and the one event that matters is buried among them. On the right each account is judged against its own past: the engineer's night work is unremarkable, and the accountant's 03:00 event is the only thing left to look at. Nothing about the events changed, only what they were compared against.

A systems administrator who works nights and authenticates to database servers no one else touches is a persistent outlier and not an intruder. Conversely an account whose behaviour has just changed completely may still sit inside the population's bulk, because the values it moved onto are ordinary for other people. Both errors have one cause: "is this event unusual for this organisation" is not "has this account departed from its own behaviour". The two differ in the reference set against which an observation is judged exchangeable — all accounts, or one account's history. Conditioning on the entity is this paper's whole commitment, and §5.1 shows it is where the discriminating information on this corpus lies.

1.3 Contributions, and what is not claimed

We contribute a family of entity-conditioned nulls over heterogeneous log fields requiring no advance declaration of a field's type, cardinality or value set (§3.2); a measurement of what per-entity conditioning is worth at matched budgets, with intervals (§5.2); a structural census identifying which properties of an event carry the discriminating information (§5.1); per-mechanism sensitivity against planted attacks constructed to hold population rarity out (§5.3); and a bound on what any allocation of a fixed budget across detectors can achieve (§5.5–5.8).

We do not claim state-of-the-art detection: 15.7% precision at the tightest budget is good against this base rate and not good enough to act on unattended. We do not claim that combining evidence helps, nor that population-scope conditioning is useless — it retains one capability this framework lacks (§5.7). And we do not claim generalisation beyond authentication telemetry of this shape, nor to the full population: every figure is measured on entity subsets (§2.2).

The framework is stated as six requirements, referred to by number throughout.

	REQUIREMENT
R1	A verdict is a function of the event and of persisted state only, so scoring is reproducible from the record and independent of batching.
R2	No component requires advance knowledge of a field's type, cardinality or value set. One field must be declared the entity, and one the timestamp; nothing else.
R3	Abstention is an outcome. A component with no basis for an opinion says so, and does not contribute a neutral value.
R4	Scoring is deterministic: no wall clock, no randomness, and a canonical total order before every floating-point reduction.
R5	A verdict carries the evidence needed to reconstruct it.
R6	Alert volume follows from a stated exchange rate between a missed intrusion and a wasted investigation, not from a quota.

2. Data and evaluation design

2.1 Telemetry and labels

We use the Los Alamos comprehensive cyber-security events data set [2], released CC0, and specifically its authentication log: 1.05 billion events over 58 days from 12,425 users and 17,684 computers, with a labelled red-team exercise embedded.

The unit of analysis is a human account. Machine accounts, `SYSTEM` and `ANONYMOUS LOGON` are excluded — they are not individuals — at no cost in labels, since all 104 accounts the red team touched are human.

The label file carries 749 rows, 715 distinct, naming 104 accounts, and is highly concentrated: 93.6% of rows share one source computer, and two of the seven scored days carry 482 of the 700 post-boundary labels. The effective sample size is therefore far below 549 (§6.2).

Two corpus properties bear on specific detectors. Distinct human-user counts follow a weekly cycle, about 12,800 on weekdays against 5,400 at weekends, which a null over an account's hour or event count must absorb. And failed authentications appear only for accounts that succeeded somewhere in the data set, so the failure population is conditioned on eventual success — a property of the archive rather than of a live stream, and one the detectors score.

2.2 Windows, entity population and sampling

The first seven days are a burn-in window: events are scored, so state warms under exactly the code path scoring uses, but nothing is emitted or counted. Two quantities are fitted there and frozen at the boundary — a between-detector covariance and a conformal calibration (§3.3) — and neither is ever updated by an event it is later used to score. The window was fixed before any end-to-end measurement, recorded by the commit that fixed it, and costs the 49 labelled events inside it. Scoring runs over days 7 to 13 inclusive.

Three of the four designs below are entity samples, taken because a fixed alerts-per-day budget is a far harder target on 42.2 million events than on 4.2 million. Every labelled account is retained in every sample, which inflates the labelled share, so each base rate is stated.

DESIGN	SELECTOR	SCORED EVENTS	LABELLED	BASE RATE
full	none	42,218,530	549	1.30×10^{-5}
`r11`	1 entity in 16, residue 11	4,190,603	549	1.31×10^{-4}
`inj`	1 entity in 16, residue 7, plus planted attacks	4,494,396	1,405	3.13×10^{-4}
`holdout-r7`	days 7–8 of the residue-7 corpus	1,427,225	262	1.84×10^{-4}

Because labelled accounts are exempt from sampling, the residue-7 and residue-11 corpora share their labelled events and differ only in background and window. A result reproduced across them is a check on sensitivity to background, not an independent replication, and is described as the former.

2.3 Planted attack mechanisms

The real campaign supplies one uneven mixture, which cannot separate "this detector cannot express this mechanism" from "this corpus barely contains it". We therefore plant six named kinds into a held-out copy, eight victims each, entirely inside the scoring window. Victims are disjoint from every account the real labels name, so the account alone determines which ground truth an event belongs to.

MECHANISM	CONSTRUCTION	EVENTS	PREMISE ISOLATED
credential spray	many never-used destinations within ten minutes	320	categorical novelty and its rate
lateral chain	connected hops, each sourced from the previous destination	40	novel *pairings* of real values
off-hours	only familiar values, twelve hours from the account's window	64	the circular timing null alone
privilege escalation	an authentication type absent from the account's history	24	novelty on a low-cardinality field
low-and-slow	familiar values only, a modest sustained volume increase	288	the volume null alone
account takeover	destination, authentication type, logon type and hour all change	120	an upper bound: everything at once

The decision that matters statistically is the choice of planted value: **the most population-common value the victim has never used**. Sampling the vocabulary uniformly instead plants population-rare values, and a population-rarity test then detects the plant for the wrong reason. Choosing the most ordinary unused value tests per-entity novelty with population rarity held out, which is the only construction under which §5.3 separates the two questions this paper is about. §5.3 reports where that construction succeeds and where the cardinality of the substituted field defeats it.

Value choice is deterministic given the corpus, so every victim of a kind receives the same planted values: the events of one kind are not independent draws and the effective sample size is nearer eight than the event count. Sensitivity against planted labels is a claim about whether a test responds to a mechanism, not about detecting an intrusion, so the two ground truths are reported side by side and never summed.

---

3. Method

3.1 The entity-conditioned null

Write an event as field–value pairs with an entity *e* and a time *t*. For each field the framework maintains a per-entity summary of *e*'s history, decayed exponentially in event time with a seven-day half-life, and asks

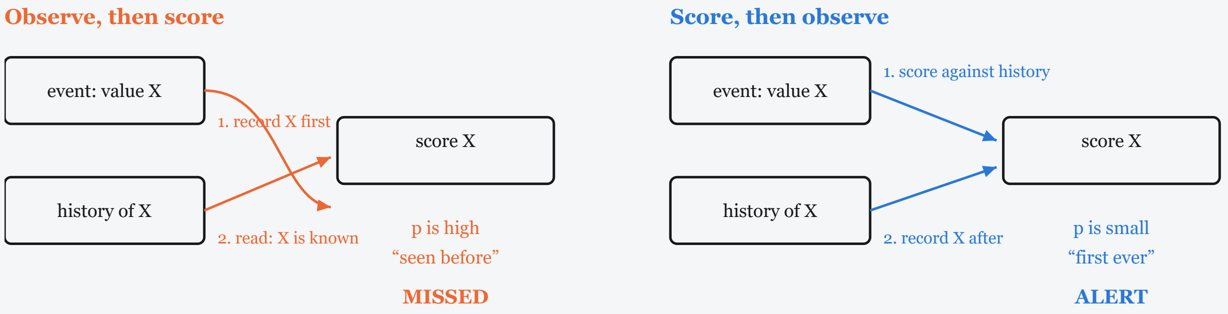
```
H₀ : this observation is exchangeable with e's own decayed history for this field.
```

Six such questions are asked, each returning a p-value under its own null or abstaining. Nothing is specific to authentication: what makes a question available is the inferred kind of the field, not its name.

DETECTOR	QUESTION	PREDICTIVE	SCOPE
novelty	has *e* taken this categorical value before?	Dirichlet–multinomial over decayed counts	per-entity
novelty rate	is *e* producing first-ever values faster than it historically does?	Beta-binomial over *e*'s own novelty rate	per-entity
timing	is this hour unusual for *e*?	von Mises KDE on the 24-hour circle, truncated Fourier	per-entity
volume	is *e*'s activity this period unusual for *e*?	Gamma–Poisson over completed periods	per-entity
pairing	has *e* combined these two values before?	novelty's estimator on a composite field	per-entity
marginal	is this value rare across the whole population?	Dirichlet form over decayed population counts	population

Two properties of the table are load-bearing. Novelty's reserved mass for a first-ever value is $a/(n + a(K+1)) \approx 1/n$, so **the p-value for a first-ever value is set by the length of the account's history rather than by how surprising the value is** — the detector's most important property and its principal weakness (§6.2). Novelty rate exists because of that weakness and asks a scale-free question instead, carrying a posterior over *e*'s own rate so that a second novel value from an account with twenty events of history is not called overwhelming. Volume's predictive is deliberately over-dispersed relative to the Poisson, which makes it tolerant of ordinary bursts and, as §5.3 shows, blind to sustained small increases.

A detector may score several fields; its arm takes the most extreme, with a Šidák correction where it combines fields internally.

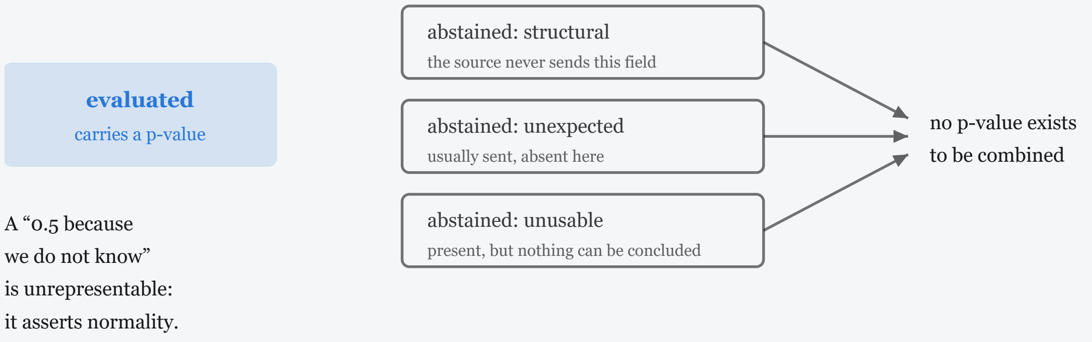


Both arrangements return a number. Only one of them is measuring anything.

The failure is silent, which is what makes it dangerous. Update state before scoring and a first-ever value is already a known value by the time it is judged, so novelty detection dies while still emitting plausible p-values. Nothing in the output announces it. The framework therefore makes the ordering unexpressible rather than conventional: `Score` holds no means of writing, and the update it computes does not exist until it has produced it.

Ordering is the leakage control: every detector scores against pre-event state, the combination is computed, and only then are observations committed. A first-ever value is therefore still novel when scored. The rule cuts the other way too — because an event updates *e*'s state after being scored, a sustained intrusion progressively enlarges its own reference set, which §6.2 treats as a live threat rather than a solved problem.

3.2 Inferring what a field is, and declining to answer



Declining is not the same as reporting nothing unusual. A verdict has four states and only one of them carries a p-value, so a detector with no basis for an opinion cannot express a confident middle value — the field is unreachable. An abstention reduces the degrees of freedom of the combination rather than contributing to it. This is what lets the system degrade honestly instead of inventing findings when a source changes shape.

R2 requires that no component be told a field's type. A registry observes values as they arrive and settles each field into one of five kinds — categorical, boolean, discrete, continuous, identifier — after which detectors iterate the registry rather than a list of names.

The identifier kind carries the weight. A field whose values are almost all distinct — a session GUID, a request id — is unbounded by construction: every value is first-ever, so a novelty test on it fires on every event and, being the most extreme thing in the queue, consumes the whole budget. Detectors decline such fields. Without that, the framework's headline arm is a random-number generator with a large p-value.

R3 makes abstention an outcome: it reduces the number of tests combined rather than contributing a p-value of one. At this base rate that matters, because a neutral value entered into a combination over six tests is not neutral but evidence of ordinariness, and in Fisher's sum five such values bury one informative test.

3.3 Combination and calibration

Given J evaluated p-values for one event, four rules turn them into one decision.

RULE	STATISTIC	WHAT IT ASKS
composite	Fisher's $X^2 = -2\,\Sigma \ln P_j$ on $\chi^2(2J)$, with Brown's correction [3, 4]	is the evidence *jointly* unusual?
corrected minimum	$P = 1 - (1 - \min_j P_j)^J$, Šidák [5]	did *any* detector find *e* out of character?
union, equal cost	best rank in any detector, truncated to the shared budget	the same, with the p-value scale removed
union, equal depth	best rank in any detector, every arm keeping its own top *B*	the same, paying for the depth

Brown's correction requires a positive variance estimate for X^2, and on this corpus it does not get one: with six detectors the burn-in covariance implies $\mathrm{Var}[X^2] = -27.5$, which no joint distribution can produce. The correction is then not applied, the combination degrades to plain Fisher, and the run records that it did. **Every composite figure below is Fisher's statistic without Brown's correction.** §6.2 reads the negative estimate.

A fused rank is not calibrated against any of these nulls and carries no tail-probability interpretation; it reports a selection, and each alert still carries the p-value of the detector that raised it. Rank collisions are structural — every detector has a rank 1 — and break on event identity rather than on log P, which would hand each collision to whichever detector's numbers happen to be smallest.

Conformal calibration [6] is applied optionally and orthogonally, replacing each detector's model tail with that value's rank in its own burn-in distribution, which is super-uniform whether or not the model is correct. Being monotone it cannot change any single detector's ordering, so per-detector figures are identical with and without it; what it changes is which detector supplies the minimum. It floors every p-value at 1/(n+1), with the model log p-value as tie-break.

---

4. The decision problem

R6 states that alert volume follows from a stated exchange rate rather than a quota, because quotas are pathological: a system tuned to emit 100 alerts a day emits 100 on a quiet day too, all benign. If nothing happened, the right number of alerts is zero. We score an alerting configuration by

```
U = v·TP − c·FP,
```

with v what catching one incident is worth and c what one wasted investigation costs. Only v/c is identifiable from counts, so an operator supplies one number, and a queue is worth reading exactly when TP/FP > c/v.

Maximising a ratio does not work, and the failure is structural. TP/FP is precision under the monotone transform P/(1−P), and precision's maximiser is the smallest queue containing a true positive; forbidding TP = 0 moves that corner from "alert on nothing" to "alert on one thing" rather than removing it. **Any objective that is a function of precision alone is scale-free, and a scale-free quantity cannot say how many rows to show.** The same argument disposes of accuracy, balanced accuracy, F1 and Youden's J: each is an unstated exchange rate wearing a metric's clothes. Accuracy is the sharpest case — alerting on nothing scores 99.9987%.

A budget is therefore a **ceiling rather than a quota**: within it the queue is truncated where marginal alerts stop paying. §5.6 measures what that costs and buys at v/c = 10, stated in advance.

---

5. Results

All comparisons are at matched alerts per analyst-day, over the whole seven-day window, so a budget of *B* corresponds to 7*B* alerts.

5.1 What distinguishes the campaign

Before any detector, what property of a labelled event could a method exploit? We census five structural properties of an event relative to the history it was scored against, defined by facts about the event and the history and never by which detector produced the smallest p-value — a partition defined by our own detectors would flatter the framework by construction. On `r11`, 4,190,603 scored events of which 549 are labelled:

PROPERTY	LABELLED	SHARE	BACKGROUND	SHARE	LIFT
novel pairing for this entity	362	65.9%	19,841	0.473%	**139**
novel value for this entity	215	39.2%	8,913	0.213%	**184**
volume burst for this entity	199	36.2%	1,143,820	27.3%	1.3
outside this entity's hours	181	33.0%	1,576,171	37.6%	0.9
population-rare value	0	0.0%	4,835	0.115%	**0.0**

The properties are not mutually exclusive and 92 labelled events exhibit none of them.

Population rarity is not merely weaker, it is **empty**: not one labelled event holds a population-rare value while 4,835 background events do, so a population-rarity test on this campaign is a test of something the campaign does not exhibit. That is the strongest form this paper's central claim takes, and it is a statement about this campaign — §5.3 shows the same property behaving differently on planted attacks. Volume bursts and out-of-hours activity are not enriched at all, which bounds what work on those two detectors could recover here; §6.2 gives the other half of the explanation for each, and it is not the enrichment.

5.2 Detection on the real campaign

`lanl-r11-b1000-weighted-d7-14-005`, 549 labelled among 4,190,603 scored. Every proportion carries a 95% Wilson interval [7]; §6.2 states why those intervals are optimistic.

ARM	10/DAY	100/DAY	1000/DAY	PRECISION AT 10/DAY	RECALL AT 1000/DAY
novelty	**11**	**60**	**201**	**15.7% (9.0–26.0)**	36.6% (32.7–40.7)
pairing	4	59	127	5.7% (2.2–13.8)	23.1% (19.8–26.8)
novelty rate	0	22	185	—	34.9% (31.0–39.1)
timing	1	2	7	1.4% (0.3–7.7)	1.3% (0.6–2.7)
volume	0	0	0	—	0.0% (0.0–0.7)
marginal	0	0	0	—	0.0% (0.0–0.7)
corrected minimum	4	47	162	5.7% (2.2–13.8)	29.5% (25.8–33.5)
composite	0	6	113	—	20.6% (17.4–24.2)

At the tightest budget novelty returns 11 true positives in 70 alerts, a lift of about 1,200 over the base rate; precision falls to 2.9% at 1000 alerts a day as recall rises to 36.6%, the ordinary consequence of taking a longer prefix of one ranking.

Novelty and pairing are **not distinguishable and should not be ranked**: at 100 alerts a day their recalls are 10.9% (8.6–13.8) and 10.7% (8.4–13.6), and the two questions are nearly the same question, a novel pairing being a novel value of a composite field. The volume and marginal zeros carry an upper bound rather than a point. Neither combination reaches its best component at any budget, and the composite's zero at the two tighter budgets is not an artefact calibration removes — those figures are *with* conformal calibration, and without it the composite reaches 0 at 100 a day rather than 6.

On a corpus differing in background (`holdout-r7-fixed`, 262 labelled among 1,427,225) novelty gives 2, 8, 15 and 21 at 10, 25, 50 and 100 alerts a day and the composite 0 everywhere.

5.3 Detection by attack mechanism

The planted corpus separates "cannot express this mechanism" from "cannot afford it". `lanl-inj-b1000-weighted-d7-14-005`: 856 planted events across six mechanisms plus the 549 real labelled events, attributed by victim account.

The budget binds harder than the method. At 10 alerts a day no arm reaches any planted mechanism — the only detections anywhere are 11 real-campaign events to novelty and 4 to pairing. At 100 a day exactly one mechanism is reached, account takeover, by the marginal (76) and the composite (26). At 1000 a day five of six are, as below. For four of the six mechanisms the sentence "this framework does not detect it" is therefore false at some budget and true at another, and only the budget changed.

At 1000 alerts a day, planted totals in the header. Every row spends the permitted 7,000 alerts except the equal-depth union, which spends 31,505 (×4.5), and the baselines, measured at their own budgets on the sampled corpus of §5.7.

METHOD	SPRAY /320	LATERAL /40	OFF-HRS /64	PRIV-ESC /24	LOW+SLOW /288	TAKEOVER /120	REAL /
`novelty`	80	15	0	0	0	30	**178**
`noveltyrate`	**117**	**26**	0	**4**	0	64	173
`pairing`	0	0	0	0	0	12	130
`timing`	0	0	**3**	0	0	11	7
`volume`	0	0	0	0	0	0	0
`marginal`	0	0	0	0	0	**120/120**	0
composite	0	4	0	0	0	116	107
corrected minimum	40	10	0	0	0	28	156
union, all arms, equal cost	0	0	2	0	0	**120/120**	99
union, all arms, equal depth	**117**	**26**	**3**	**4**	0	**120/120**	**265**
`lof` — baseline	0	0	0	0	**12**	0	0
`ocsvm` — baseline	0	0	0	0	0	33	0

No single method is best at more than one thing. The marginal takes every planted takeover and nothing else; novelty rate takes spray, lateral movement and privilege escalation; novelty takes the real campaign. A reader looking for one row to deploy will not find one, which is what §5.8 formalises.

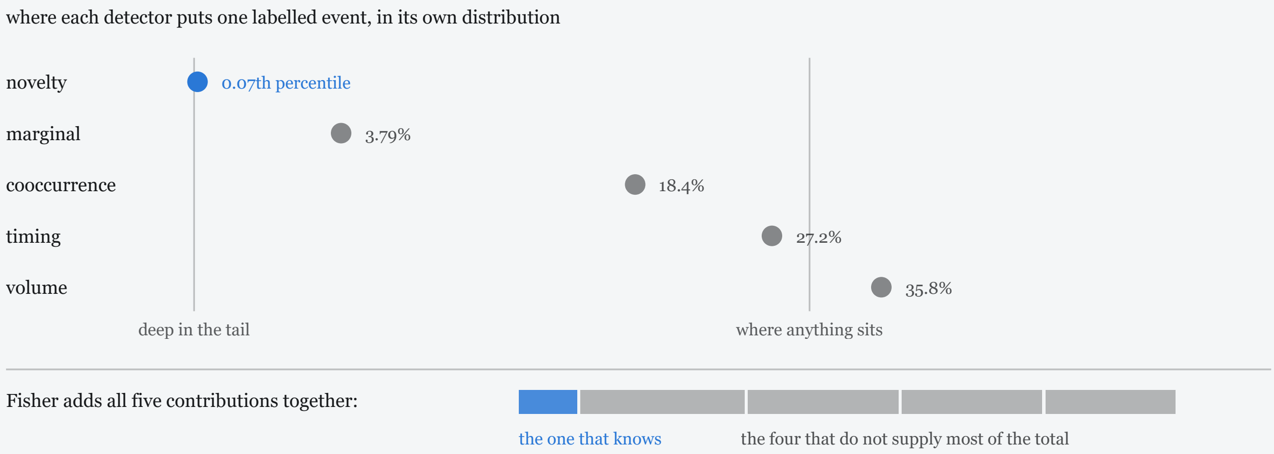
Low-and-slow is reached by no arm at any budget — 0 of 288, 0 of 8 victims. It is the mechanism volume's over-dispersion is built to tolerate, so this is a confirmed prediction; §6.2 reports that volume's response to it is in addition *inverted*, and §6.3 the statistic that repairs the direction.

The marginal's 120 of 120 needs explaining, since the corpus plants the most population-common unused value precisely to hold population rarity out. Its median p-value is 0.59 on spray and lateral movement, which substitute the destination computer, 0.17 on privilege escalation, which substitutes the authentication type, and 3.8×10^{-5} on takeover, which substitutes three fields at once: the pattern follows the **cardinality of the substituted field**. Destination takes 3,535 distinct values, so a common value the victim has not used is genuinely common and the marginal is unmoved; authentication type takes 14 and logon type 10, with Kerberos, NTLM and Negotiate accounting for 99.6% of resolved types, so an account already using the common values can only be given one from the tail. **Holding population rarity out succeeds where the vocabulary is large and cannot where it is small** — a limitation of the planted corpus, stated because the alternative is to read the row as evidence for a mechanism the design excludes.

5.4 Combination and budget allocation

RULE	10/DAY	100/DAY	1000/DAY	ALERTS AT 1000/DAY
best single arm	**11**	**60**	**201**	7,000
union, per-entity arms, equal cost	2	27	106	7,000
union, all arms, equal cost	2	21	96	7,000
union, per-entity arms, equal depth	11	74	278	25,930 (×3.7)
union, all arms, equal depth	11	74	278	32,134 (×4.5)

At equal cost the union is strictly dominated at every budget, with non-overlapping intervals at the widest: recall 17.5% (14.5–20.9) against 36.6% (32.7–40.7). No exchange rate rescues a dominated option. At equal depth it finds what no single arm finds, 278 against 201 and recall 50.6% (46.5–54.8), for 3.7 times the alerts.



At 100 alerts a day, of 262 labelled events: novelty alone 21 · most-extreme-of-five 20 · **the five-detector sum 0**

More evidence is not better when most of it is not evidence. Fisher's method asks whether the evidence is jointly unusual, which is the right question only when every detector is informative. Here one is: it places the median labelled event at the 0.07th percentile of its own distribution, more extreme than 99.93% of all traffic. The other four place it where any event would sit. The sum is dominated by the four, so a composite built from a component that finds 21 labelled events finds none — and no cleverer combiner recovers it, because the remedy is not a better average but not averaging in detectors that know nothing.

The two p-value rules fail for different reasons, and the union isolates them. **Fisher's sum averages an informative test with uninformative ones**: labelled events sit at the 0.07th percentile of novelty's own distribution and between the 18th and 36th of every other detector's, so summing $-2 \ln P$ over six tests dilutes one signal with five non-signals — Fisher's method is powerful against diffuse alternatives and the minimum against sparse ones, and this alternative is sparse. **The corrected minimum compares p-values across tests sharing no scale**: novelty supplies 5,979 of the 7,000 retained alerts, 85%, and volume never supplies the minimum at all.

Removing the scale mismatch made the marginal's signal reachable and the equal-cost result got *worse*, so the mismatch was not the binding defect: novelty holding 85% of the queue was closer to correct than crowding-out suggests, because it is the better arm. The diagnosis left is that a fixed budget divided among six arms gives each about a sixth of the depth it had alone.

5.5 Allocation by demonstrated quality, and why it cannot help

The rule measured is a per-alert likelihood ratio. Two quantities are fitted per detector on burn-in and frozen: a null over that detector's own log p-value, and the single parameter a of a Beta(a, 1) density over the null quantiles its labelled burn-in events received. An alert at quantile q from a detector of weight a scores $s = \ln a + (a - 1) \ln q$, the log-likelihood ratio of its being labelled against its being background. Alerts from detectors sharing no p-value scale are comparable on s, so the budget goes to the highest scores and no share parameter is chosen. A weight is retained only where twice its log-likelihood ratio against $a = 1$ exceeds 2.706, the 5% one-sided point at the boundary of the range [10]; without that guard, fifty uniform draws fit $a \approx 1 \pm 0.14$ and noise alone buys a large share of the queue. Labelled events a detector evaluated without surfacing enter right-censored.

The fit separates the detectors as intended — on `r11` the three per-entity arms are informative at $a = 0.376$, 0.414 and 0.491, while timing, volume and the marginal surface none of the 49 labelled burn-in events, are fitted uninformative and cost nothing. It is not enough.

RULE	`R11` 100/DAY	`R11` 1000/DAY	`INJ` 100/DAY	`INJ` 1000/DAY
best single arm	**60**	**201**	**76**	384
weighted, burn-in weights	56	164	56	231
weighted, oracle weights	61	174	61	309
best two-arm split, oracle	60	**201**	77	**395**

The two oracle rows read the labels they are evaluated against and bound what a fitted rule could reach. The burn-in rule loses at every budget on both corpora, which alone would leave the diagnosis open — 49 labelled events is a thin sample for ranking six detectors, and a rule may be sound while its estimator is starved. Refitting on the evaluation labels settles it: those weights separate the arms properly, 0.19, 0.22 and 0.23 for the per-entity arms against 0.71 for timing and 1.0 for volume, and the rule still loses. **The construction fails, not the fit.**

An exhaustive search over two-arm splits, again oracular, shows why: on the real campaign the optimum is the corner at both budgets, and diverting 5% of the budget costs 13 detections at 1000 a day, so the derivative is negative *at* the corner. The mechanism is that **the arms are substitutes rather than complements** — 74.6% of novelty rate's detections are also found by novelty and 78.7% of pairing's are, so splitting halves each arm's depth and what survives largely coincides.

Where the arms are genuine complements the same search finds headroom, which is the control this argument needs. On the planted corpus the marginal's 76 detections at 100 alerts a day overlap the per-entity arms' by **zero** — the two scopes catch disjoint events there — and the best split gives the marginal 75 alerts and novelty 25, for 77 against 76; at 1000 a day, the marginal 150 and novelty rate 850, for 395 against 384. Both optima sit on a plateau, both gains are inside sampling error, and both are on planted rather than real attacks. **Overlap is what decides whether dividing a budget can pay**, and on this corpus no division beats the best detector alone.

5.6 Truncating where the objective peaks

At v/c = 10 as stated in §4, on the corrected-minimum arm:

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	**30**	4	5.7% → **13.3%**	40 (57%)	**0**
100/day	700	47	**221**	47	6.7% → **21.3%**	479 (68%)	**0**
1000/day	7,000	162	**315**	74	2.3% → **23.5%**	6,685 (95%)	88

At the two tighter budgets the truncation is free. At 1000 it becomes a decision: the objective discards 6,685 alerts and 88 true positives with them, because at this rate those 88 do not pay for 6,685 wasted investigations. For the composite the optimum is to emit nothing at any budget, including the one at which it finds 113 true positives. An objective declining to deploy a detector is a usable answer. This is an oracle bound — the optimum is located using the labels — so it measures the headroom a cutoff has rather than being a deployable rule.

Reporting at a nominal false discovery rate is not available on this corpus. Benjamini–Hochberg [8] per day on the composite at q = 0.05 yields 5,352 discoveries of which 113 are labelled, a realised FDR of 0.979 (0.975–0.982) with five of seven days saturated; Benjamini–Yekutieli [9] gives 0.978 at q = 0.001. The nominal level has no purchase because the p-values are not calibrated, which is a property of the composite rather than of the procedures.

5.7 Population-scope baselines

Eight reference implementations spanning four inductive biases were run on the same events with the same labels and budgets: isolation forest [11], extended isolation forest [12], half-space trees [13], local outlier factor [14], one-class SVM [15] and PCA reconstruction error, from scikit-learn [16], plus an uncalibrated per-entity EWMA z-score. The one-class SVM is a Nyström kernel map with a stochastic-gradient objective rather than the exact kernel machine, which is $O(n^2)$ in the fit set at this row count; the deviation is recorded as one.

On the matched comparison all six population models detect **0 at every budget**, which §5.1's census explains: not one labelled event of the real campaign holds a population-rare value. On the planted corpus the exception is the interesting one — one-class SVM detects 33 of 120 planted takeovers and **local outlier factor 12 of 288 low-and-slow events, the one mechanism no arm of this framework reaches at any budget**. A sustained small departure is what volume's over-dispersion tolerates and what a density estimate has no such tolerance for: a capability this framework does not have, and why the two scopes are complementary rather than ordered.

Both figures come from an easier problem in one way that dominates: the models read a 1-in-100 sample of 45,071 rows rather than 4.49 million events, raising the labelled share from 0.031% to 3.1%. Given a hundredfold easier problem they reached 33 and 12.

5.8 Allocation under an adversarial mix

§5.5 found the optimum at the corner. Read §5.3 as a payoff matrix — rows detectors, columns the mechanism an adversary chooses, entries P(detected | mechanism) — and that result is a theorem rather than a measurement. Under a known mix p the expected detection of a randomised allocation w is $w^{\mathsf{T}}(Ap)$, which is **linear in* w***; a linear form on a simplex attains its maximum at a vertex. So no prior-weighted mixture, including one fitted to published incident statistics, can beat the best single detector. Checked over 20,000 random priors, mixtures strictly beating the best single arm: none. The equilibria below are the minimax solutions [18], computed by Dantzig's reduction to a linear programme [19]; `robust-inj-d7-14-001`.

Three objectives, on the seven mechanisms of §5.3 with `lof` admitted so that every column is reachable. Expected rate is under a prior weighted towards credential attacks and takeover:

OBJECTIVE	GUARANTEE	EXPECTED RATE	WORST-CASE RATE	ALLOCATION
best single arm	**0**	**0.372**	0	any one arm — each is blind to some mechanism
maximin	0.019	0.059	0.019	`lof` 0.47, `timing` 0.42, `noveltyrate` 0.12
competitive ratio	**0.296 of achievable**	0.154	**0.012**	`lof` 0.30, `noveltyrate` 0.30, `timing` 0.30, `marginal` 0.11

Without `lof` the game's value is exactly zero. Every arm scores 0 on low-and-slow, so the saddle point is (any arm, low-and-slow) and a rational adversary wins with certainty. No reweighting of rows changes a column of zeros: the defect is coverage, not allocation, and it is why §5.5's negative result cannot be repaired by a better allocation rule.

Maximin is a poor objective even with the column covered, being hostage to the mechanism nobody catches. Normalising each mechanism by the best rate any arm reaches against it and maximising the worst-case retained fraction is well posed, and its optimum **equalises**:

SPRAY	LATERAL	OFF-HRS	PRIV-ESC	LOW+SLOW	TAKEOVER	REAL
0.296	0.296	0.296	0.296	0.296	0.296	0.300

Six of seven sit exactly at the guarantee; only the real campaign is not binding. **No rule in §5.4 or §5.5 guarantees anything at all** — each retains 0 against its worst mechanism — and this is the only allocation that does. It costs **59% of expected detection** to buy that, and which side of the exchange an operator wants is what §4's objective decides.

Randomising is not dividing, and only dividing had been tested. §5.4 and §5.5 measure unions and splits, which give every arm a fraction of its depth. A mixed strategy runs one arm at *full* depth chosen by lottery, and is exactly evaluable from the per-arm detections already recorded. Total labelled events found on `inj` at 1000 alerts a day, all at 7,000 alerts except where noted:

RULE	FOUND	WORST-CASE RETAINED
best single arm (`noveltyrate`)	**384**	0
corrected minimum	234	0
composite	227	0
union, all arms, equal cost	221	0
randomised, even over the two best arms	344	0
randomised, competitive-ratio mixture	137	**0.296**
union, all arms, equal depth *(31,505 alerts)*	535	0
per-entity routing, oracle floor	460	—
per-entity routing, oracle ceiling	535	—

Randomising at equal cost beats every combination rule tested, 344 against 234, and still loses to the best single arm, which is what linearity requires. The routing rows are the interesting ones. **Routing is not a global allocation**: it chooses per entity, so it can send an established account to a per-entity null and a cold one to the population null and collect both, and it is therefore the only construction here that can exceed the best single arm at equal cost. The floor routes each mechanism to the arm reaching it most, which any per-entity policy matches by construction; the ceiling is the union of all arms at full depth, since no routing reaches an event no arm reaches. Both are oracles and neither charges the alert cost of attaining it.

The adversary's cost changes the answer. A value-zero equilibrium assumes an uncovered mechanism is free to mount, and low-and-slow is slow by construction. Charging λ times a stated per-mechanism cost, with low-and-slow at twelve times credential spray:

Λ	VALUE	ALLOCATION	ADVERSARY'S REPLY
0	0.019	`lof` 0.47, `timing` 0.42, `noveltyrate` 0.12	low+slow 0.47, off-hrs 0.42, priv-esc 0.12
0.005	0.043	`timing` 0.80, `noveltyrate` 0.20	off-hrs 0.78, priv-esc 0.22
0.02	0.061	`timing` 0.87, `noveltyrate` 0.13	off-hrs 0.78, priv-esc 0.22
0.05	0.092	`timing` 0.89, `noveltyrate` 0.11	off-hrs 0.89, spray 0.11

Any appreciable cost removes low-and-slow from the reply and concentrates the allocation on timing. The costs and λ are stated, never fitted: a cost fitted to the labels the allocation is scored against would make the equilibrium a restatement of the corpus. The solution concept is properly Stackelberg rather than simultaneous, the defender committing first; for zero-sum games the two coincide, and once mechanism costs differ they do not.

Finally, **where the next unit of detector work is worth spending.** Every cell whose improvement by 0.10 raises the guarantee lies in low-and-slow, off-hours or privilege escalation — the three mechanisms in the adversary's reply — and not one lies in the four columns §5.2 and §5.3 compare arms on. The largest are `timing` on low-and-slow (+0.017), `lof` on off-hours (+0.014) and `noveltyrate` on low-and-slow (+0.012). **Marginal improvement to novelty against novelty rate, which is what §5.2's headline turns on, has a shadow price of exactly zero**, and the two arms carrying every positive shadow price are the two §6.2 reports as unmeasured.

---

6. Discussion

6.1 What the evidence supports

Conditioning each null on the entity is supported on this campaign, and specifically: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, and the property a population-rarity test expresses contains none of them. That direction is what the evidence establishes, and it is narrower than "per-entity beats population conditioning" — on planted attacks the population test detects a mechanism no entity-scope test here reaches, and a population density estimate reaches a second.

Combining evidence is not supported: five rules, none exceeding its best component at equal cost at any budget, with non-overlapping intervals at the widest. The union at equal depth does exceed it at 3.7 times the alerts, and whether that trade is worth taking is what §4's objective decides.

Allocation is not supported either, and §5.8 states why in a form independent of this corpus: the objective is linear in the allocation, so its optimum is a single detector. What §5.8 adds is that the corollary usually drawn — deploy the best arm — is also wrong, because the best arm guarantees nothing against an adversary who chooses the mechanism. Both point at the same place: **coverage, not allocation**.

6.2 Threats to validity

The novelty p-value is confounded with history length, and this is the single largest methodological limitation here. For a first-ever value the estimate reduces to $a/(n + a(K+1)) \approx 1/n$. Across 32 planted victims spanning 263 to 20,666 events of history, the product of the p-value and the history length has median 1.15 and lies in [0.50, 7.22]: among novel events the ranking is close to sorting accounts by event count. Clearing the detector's realised cut needs of the order of 10^5 events of history and the busiest planted victim had 20,666, so **no attack on an ordinary account could win an alert slot regardless of what it did**. It is not straightforwardly fixable. The one principled correction tried — reserving unseen mass by Good–Turing rather than by a fixed concentration — *lost* detections, because large histories carry many singletons and the correction therefore judges a first-ever value unremarkable for exactly the accounts the working estimator ranks highest. The working configuration works for a reason the model does not state, and neutralising the covariate risks destroying the correlation the result rests on.

A sustained intrusion enlarges its own reference set. State is committed after scoring, so an event is judged against a history that excludes it — but the next event of the same campaign is not. Over a campaign persisting for days on one account the reference distribution drifts toward the attacker's behaviour. This is an untested alternative explanation for two of the paper's null results, the low-and-slow zero in particular, and cannot be separated from the stated mechanism without a run that freezes per-entity state across the campaign window.

Timing and volume are not evidence about per-entity conditioning in either direction, and §5.3's zeros for them should be read as unmeasured rather than as measured absences. Timing's tail mass was floored by its own 512-point grid at $1/(2 \times 512) = 9.77 \times 10^{-4}$, against a realised cut of 1.00×10^{-3} at 10 and 100 alerts a day: the detector could not alert whatever it observed. Volume's tail is misspecified in the opposite direction — 27,464 background events on `r11` fall below 10^{-12} where a calibrated null predicts 4.2×10^{-6}, and no labelled event goes below 1.96×10^{-7}, so its queue fills with background at every budget before a labelled event can compete. A per-entity abstention gate accounts for none of it: gating at five completed periods withholds 132 labelled events and removes only 10.6% of the pile, which is made of entities with established history, so the cause is the predictive being too narrow for their habitual variation rather than cold start. Volume's response to low-and-slow is in addition **inverted**, median p 0.72 against 0.29 on the other mechanisms. §6.3 reports what repairs each.

The remaining threats, each with the measurement establishing it and the direction it biases.

THREAT	MEASUREMENT	DIRECTION
effective sample far below nominal	549 events on 104 accounts; 93.6% of label rows share one computer; 8 victims per planted mechanism	**every interval is optimistic**
quantities chosen on the outcome	the best arm, the union's break-even rates, §5.5's split search, §5.6's optimum; 7 detectors × 5 rules × 3 budgets × 2 corpora, maxima reported	favours the framework; stated as oracle bounds, outer loop unadjusted
not measured at full population	the one full run scored 42,218,530 events with 4 of 7 detectors; its composite detects nothing	a budget is far easier on a subset
Brown's correction unavailable	$\mathrm{Var}[X^2] = -27.5$, which no joint distribution produces	**every composite figure is plain Fisher**
entity-day aggregation flatters recall	65 of 108 entity-days at 100/day, but the count-normalised form takes 65 to 14	most of the gain is the confound
§5.8 inherits its matrix's limits	event-level rates; `lof` from §5.7's 100× easier sample	`lof` is an existence proof, not a matched row

6.3 What is repaired, and what a deployable version needs

Two statistics named above have replacements, both measured and neither yet reflected in §5.3.

Timing's floored statistic is replaced by the event's ln U standardised by the mean and spread of the ln U this entity's own events have received, which has no floor. It costs two numbers of state per entity and abstains where the history is too short or, for a perfectly regular account, carries no spread — 4,847 events of 4,190,603. Detections rise from 0, 0 and 6 to 1, 2 and 7 on the real campaign and from 0, 1 and 12 to 2, 9 and 21 on the planted corpus, and the off-hours response improves rather than being traded away: median p falls from 3.20×10^{-2} to 8.23×10^{-3}, widening the separation from the nearest other mechanism from 5.7 to 18.6.

Volume's inverted response is addressed by a statistic it does not contain rather than by a refit. An over-dispersed marginal test of one period cannot see a drift that is small in every period, however well calibrated, because the evidence is in the sequence. Page's one-sided cumulative sum over per-period counts [17] accumulates it instead: with baseline λ_0 and a target shift ρ the reference is $k = \lambda_0(\rho - 1)/\ln \rho$ and $S_t = \max(0, S_{t-1} + k_t - k)$, so a sustained shift grows S linearly in the number of periods while the spread of its null grows as the square root. The p-value is the upper tail of S standardised against the entity's own realised sums, as for timing above. On synthetic streams fitted on identical stationary history, **the cumulative sum separates a sustained +30% shift from matched stationary variation by 57×, and equation (11)'s predictive by 1.2×**. `domain/drift` implements it; neither it nor the routing policy of §5.8 is scored on the corpus here, and correcting either changes every figure it appears in.

One gap separates what is measured from what can be run: **a fixed budget is a batch construction.** Selecting the top *B* of a day requires the whole day, and an operator at 14:00 does not know what arrives by 23:59; the same objection applies to a per-day Benjamini–Hochberg step-up. §4's objective does not have this defect, and §5.5's score is built to the same constraint — every quantity it reads is a property of the single alert or of state frozen before the window. What remains missing is a calibrated per-alert probability: §5.6's truncation uses labels to place alerts on one scale and is a bound rather than a rule.

One direction is closed rather than open. Learning the allocation online is the adversarial bandit setting [20], whose regret is $\sqrt{2TK \ln K}$ — 89 detection-units against 10,481 available over a year at K = 6, which looks survivable. The bound assumes the reward is observed each round. It is not: labels are the object of the search, feedback is bandit-only, and separating the top two arms of §5.2 at 80% power needs about 41,000 labelled events per arm against the 549 available. **A learner cannot converge to an equilibrium it lacks the samples to see**, so the allocation must be stated rather than learned, which is what §5.8 does.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM Conference on Computer and Communications Security, 1999.
2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events Data Set*. Los Alamos National Laboratory, 2015. CC0 1.0.
3. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
4. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
5. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. Journal of the American Statistical Association 62(318), 1967.
6. Vovk, V., Gammerman, A. and Shafer, G. *Algorithmic Learning in a Random World*. Springer, 2005.
7. Wilson, E. B. *Probable inference, the law of succession, and statistical inference*. Journal of the American Statistical Association 22(158), 1927.
8. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate: a practical and powerful approach to multiple testing*. Journal of the Royal Statistical Society B 57(1), 1995.
9. Benjamini, Y. and Yekutieli, D. *The control of the false discovery rate in multiple testing under dependency*. Annals of Statistics 29(4), 2001.
10. Chernoff, H. *On the distribution of the likelihood ratio*. Annals of Mathematical Statistics 25(3), 1954.
11. Liu, F. T., Ting, K. M. and Zhou, Z.-H. *Isolation Forest*. IEEE International Conference on Data Mining, 2008.
12. Hariri, S., Carrasco Kind, M. and Brunner, R. J. *Extended Isolation Forest*. IEEE Transactions on Knowledge and Data Engineering 33(4), 2021.
13. Tan, S. C., Ting, K. M. and Liu, T. F. *Fast anomaly detection for streaming data*. International Joint Conference on Artificial Intelligence, 2011.
14. Breunig, M. M., Kriegel, H.-P., Ng, R. T. and Sander, J. *LOF: identifying density-based local outliers*. ACM SIGMOD, 2000.
15. Schölkopf, B., Platt, J. C., Shawe-Taylor, J., Smola, A. J. and Williamson, R. C. *Estimating the support of a high-dimensional distribution*. Neural Computation 13(7), 2001.
16. Pedregosa, F. et al. *Scikit-learn: machine learning in Python*. Journal of Machine Learning Research 12, 2011.
17. Page, E. S. *Continuous inspection schemes*. Biometrika 41(1/2), 1954.
18. von Neumann, J. *Zur Theorie der Gesellschaftsspiele*. Mathematische Annalen 100(1), 1928.
19. Dantzig, G. B. *A proof of the equivalence of the programming problem and the game problem*. In Koopmans, T. C. (ed.), *Activity Analysis of Production and Allocation,* Wiley, 1951.
20. Auer, P., Cesa-Bianchi, N., Freund, Y. and Schapire, R. E. *The nonstochastic multiarmed bandit problem*. SIAM Journal on Computing 32(1), 2002.

Data and code availability

Every number here is read from a machine-generated result file committed alongside the source, each carrying its run identifier, corpus checksums, row counts, seeds and parameters. No figure is a plot of data: each is a diagram of a mechanism, so no figure can disagree with a result. §5.8's equilibria are solved from the recorded per-mechanism matrix by `cmd/robust` and need no corpus access, so they are reproducible from this repository alone. The corpus is third-party and is not redistributed; its provenance and licence are recorded with the code.

Generated by `cmd/thesis` from `docs/PAPER.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.